



ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

面向安全的可视分析

袁晓如 北京大学



DDOS TRACKING SYSTEM

Dstip Detail

Domain	
Ip	117.041.237.110
Port	3016
Tbeg	2015-09-22 18:27:22
Tend	2015-09-22 18:34:41
Types	tcp@attack@syn_flood_target



Visibility 可见性

Visualization 可视化

Visual Analytics 可视分析

可视化/可视分析

可视化(VISUALIZATION) 对事物建立心理模型(MENTAL MODEL)或者心理图像(MENTAL IMAGE)

Data



AH!

Insights

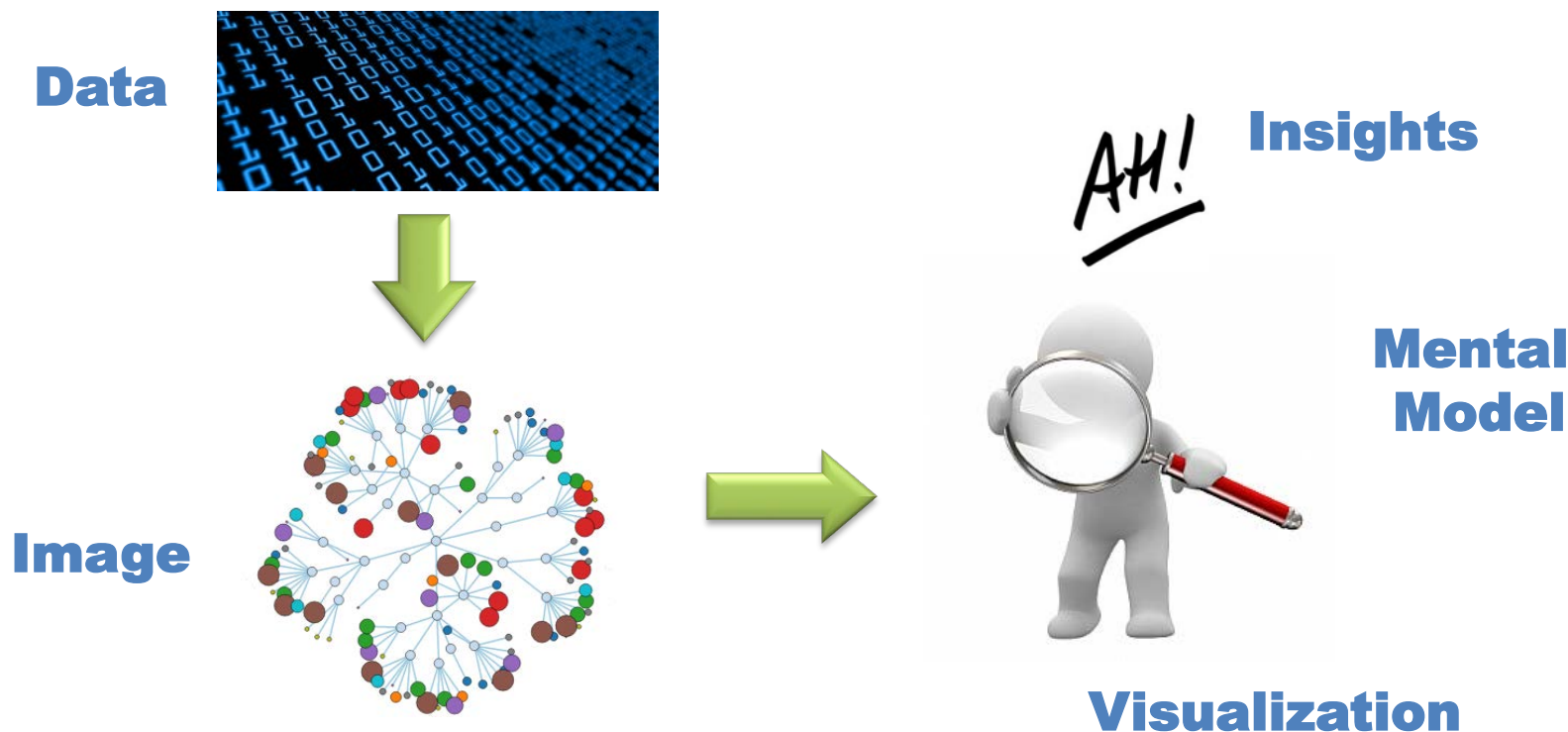
**Mental
Model**



Visualization

可视化/可视分析

可视化(VISUALIZATION) 对事物建立心理模型(MENTAL MODEL)或者心理图像(MENTAL IMAGE)

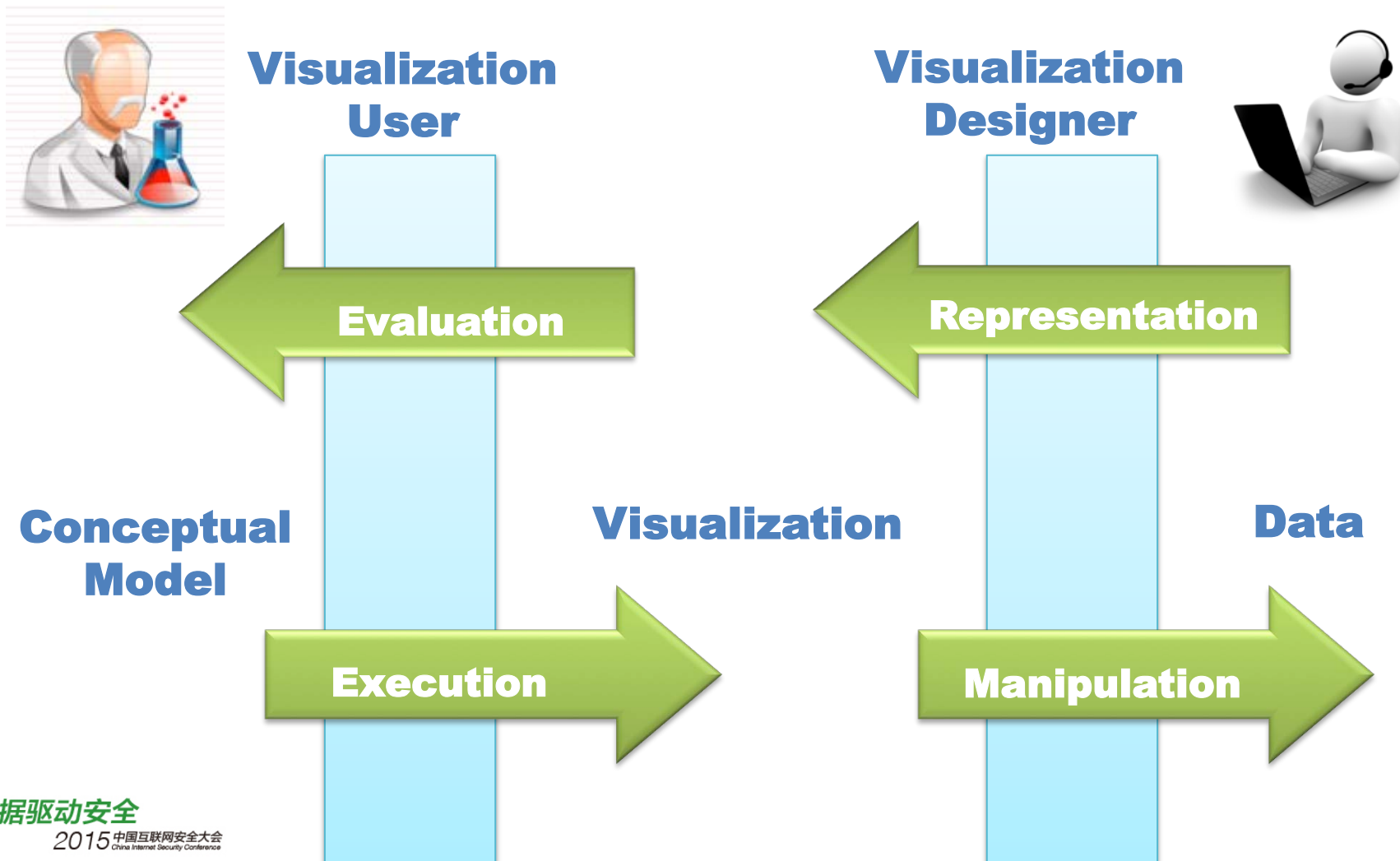


1281768756138976546984506985604982826762
9809858458224509856458945098450980943585
9091030209905959595772564675050678904567
8845789809821677654876364908560912949686

1281768756138976546984506985604982826762
9809858458224509856458945098450980943585
9091030209905959595772564675050678904567
8845789809821677654876364908560912949686

可视化模型

Double Gulf Model



可视化模型

Double Gulf Model



**Visualization
User**

Evaluation

**Conceptual
Model**

Execution

**Visualization
Designer**

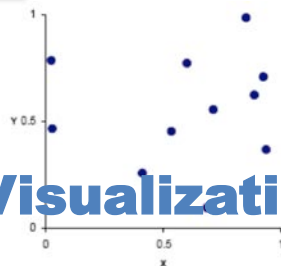
Representation



Visualization

Data

Manipulation



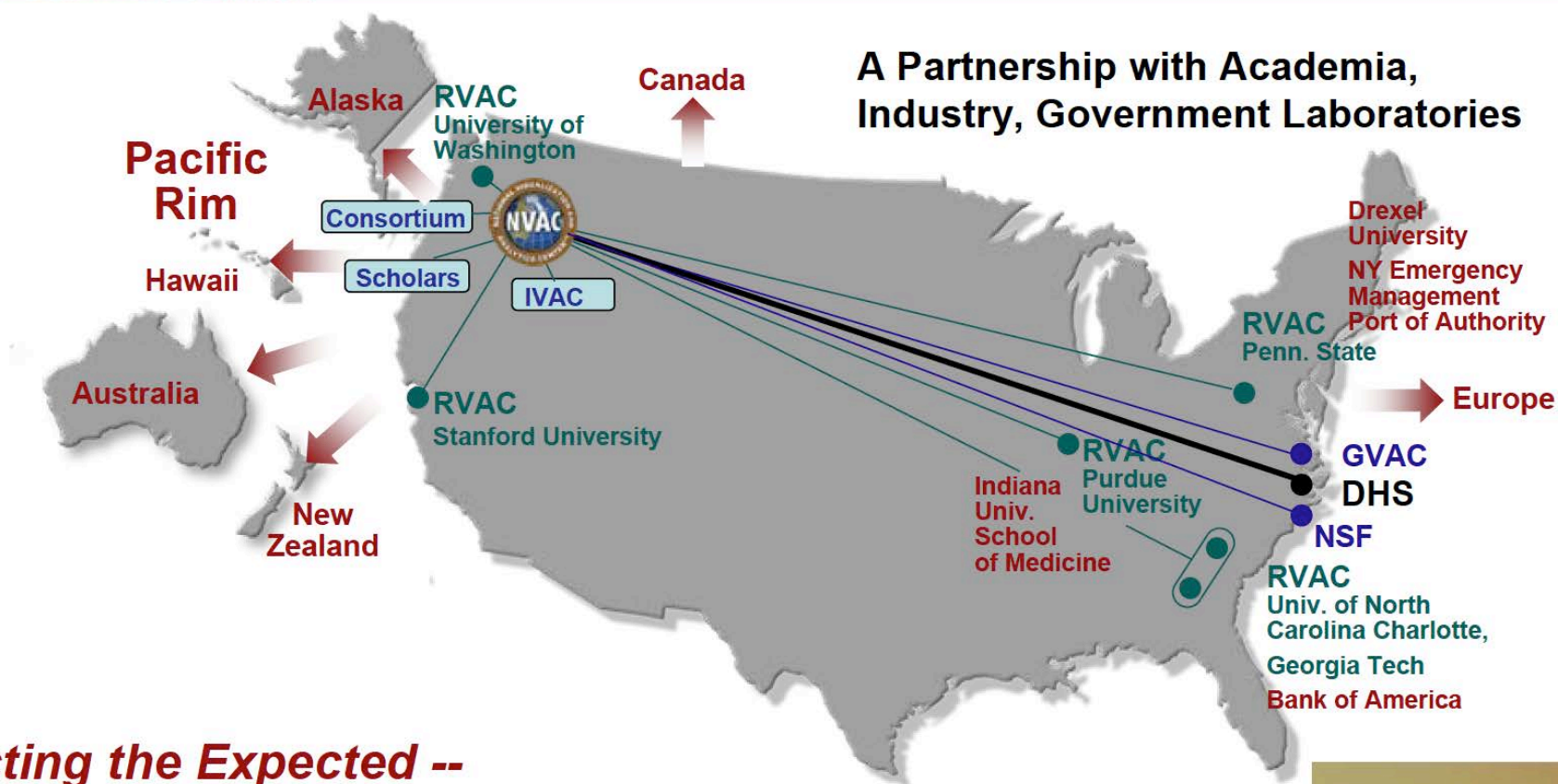
X	Y
0.67	0.79
0.32	0.63
0.39	0.72
0.27	0.85
0.71	0.43
0.63	0.09
0.03	0.03
0.20	0.54
0.51	0.38
0.11	0.33
0.46	0.46

可视分析

- 可视分析是由交互可视界面支持的分析推理的科学 (Visual analytics is the science of analytical reasoning facilitated by interactive visual interfaces)
- 从海量，动态，模糊，乃至相互冲突的数据中合成信息，洞察内涵 (Synthesize information and derive insight from **massive, dynamic, ambiguous, and often conflicting** data)
- 不漏检，有突破 (Detect the expected and discover the **unexpected**)
- 提供及时可验证可理解的评估 (Provide **timely, defensible, and understandable** assessments)
- 为评估实施行动提供有效沟通 (Communicate assessment effectively for **action**)



Visualization and Analytics Centers



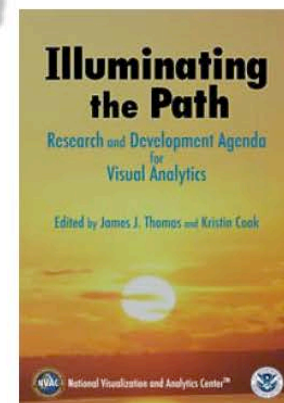
***Detecting the Expected --
Discovering the Unexpected™***

Jim Thomas

Director, U.S. Department of Homeland Security National Visualization and Analytics Center

Pacific Northwest National Laboratory Fellow

<http://NVAC.pnl.gov>



VAST CHALLENGE 2013

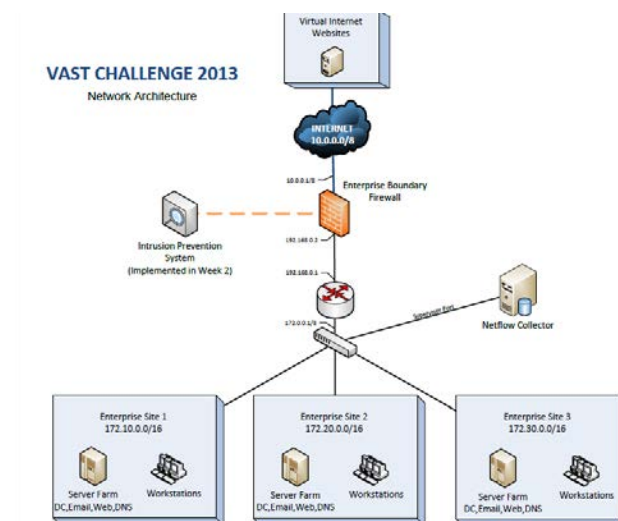
“假如你是一个公司的网络安全管理人员，你要如何从复杂的网络数据中，迅速且有效地掌握全局趋势？并及时确认异常及网络攻击行为？”

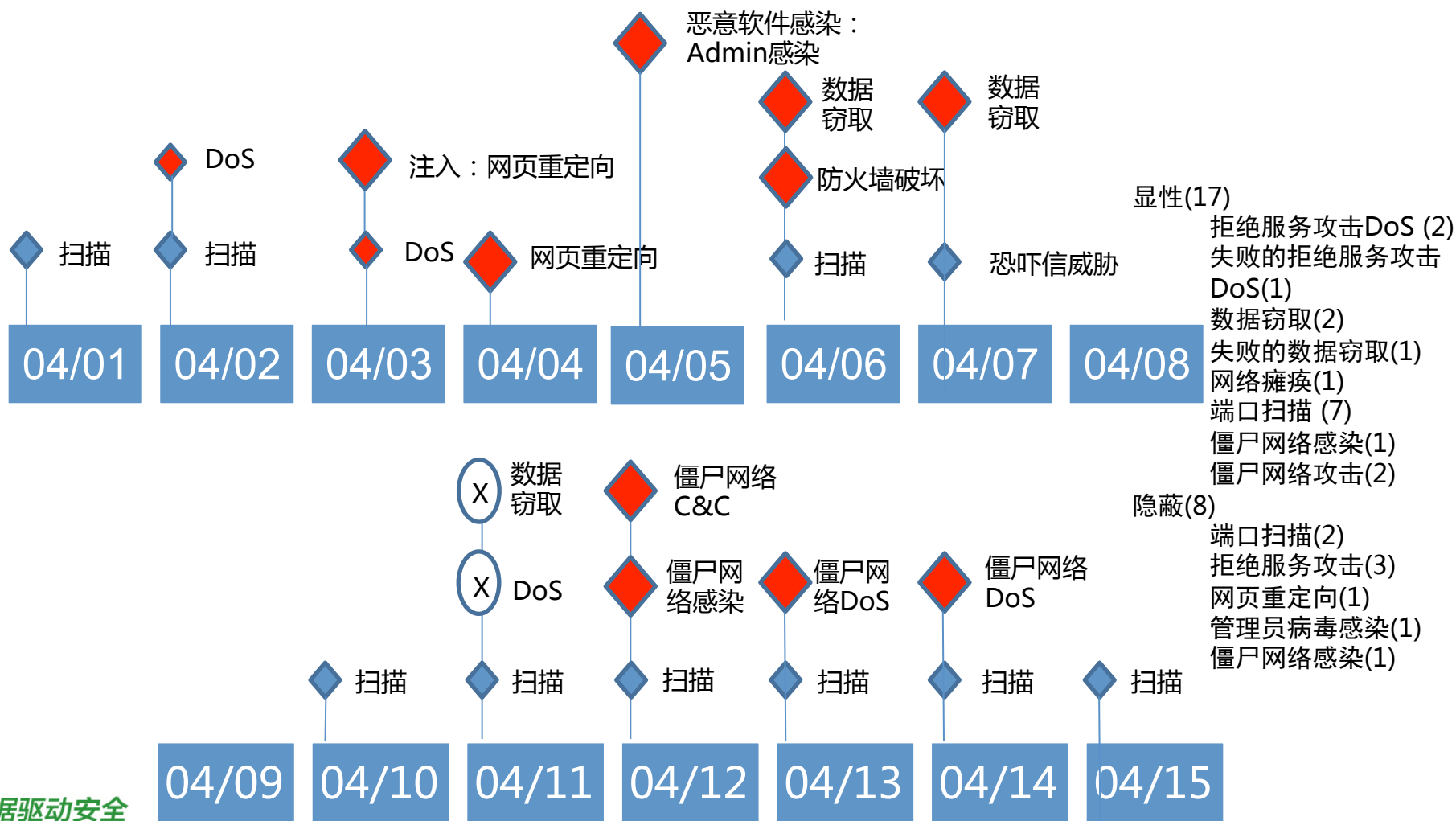
Big Marketing公司

- 这是一个国际化的负责广告与公关的公司
- 他们也会为客户提供一些网站服务
- 他们在市场上享有一定的声誉和地位，因此也有许多竞争对手虎视眈眈

你的角色 – Big Marketing公司网络管理员

- 确保公司网络（包括内网主机以及对外服务器）正常运行
- 运营、维护，并且及时确认攻击威胁及部署防御





分析任务与挑战

目标

- 快速且正确地确认发生的网络安全事件
- 实时网络事态感知

具体细节

- 提供每个网络安全事件的总体时间分布，与具体涉及细节IP与事件
- 通过寻找的事件，找到事件的关联以及背后的阴谋

数据概览

三类数据（时间跨度：两个星期）

- 网络流数据（NetFlow）
- 网络健康状况数据（Big Brother Monitor Data）
- 入侵防御系统日志数据（Intrusion Protection System Data）

数据大小

- 共约16GB
- 约一亿数据条目

数据复杂性

- 采样率不同的异构数据
- 动态连接数据
- 高维数据
- 不确定性与数据缺失

时间视图
(网络态势概览)



环状IP连接视图：
子网连接概览

细节视图
网络流细节展现

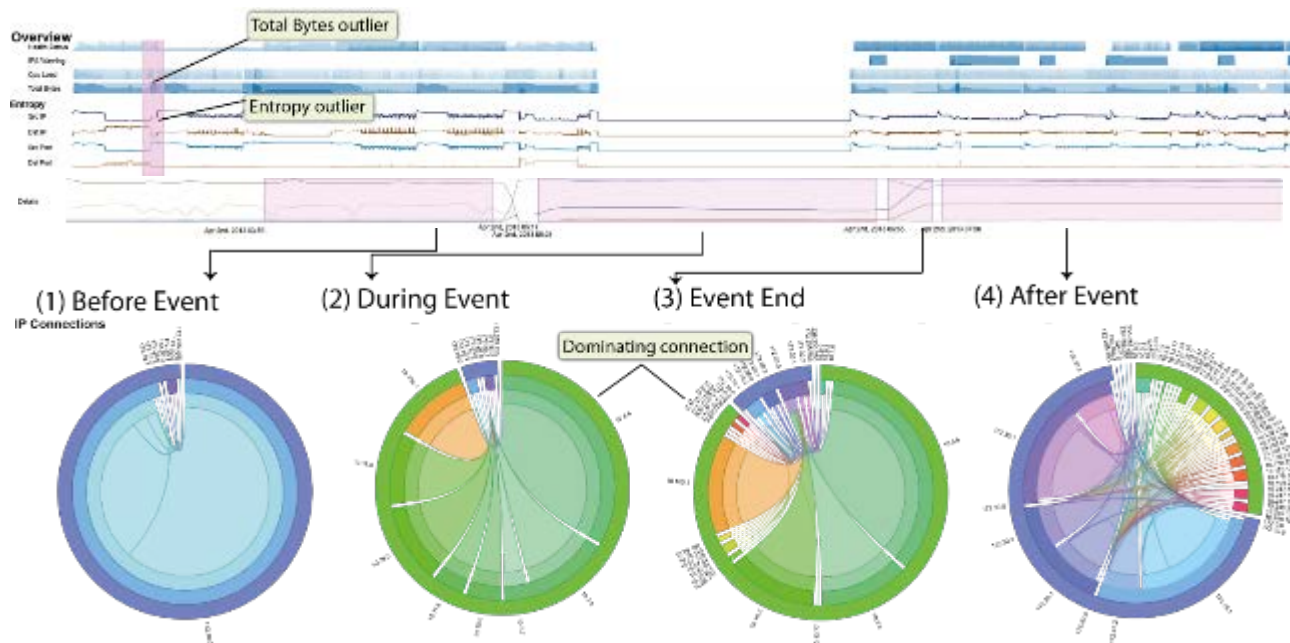
AnNetTe - Collaboration oriented visualization of network data

Siming Chen, Fabian Merkle, Hanna Schaefer, Cong Guo, Hongwei Ai, Xiaoru Yuan, Thomas Ertl
ACM VizSec 2014.

多层次可视分析 (1) --DDoS攻击检测

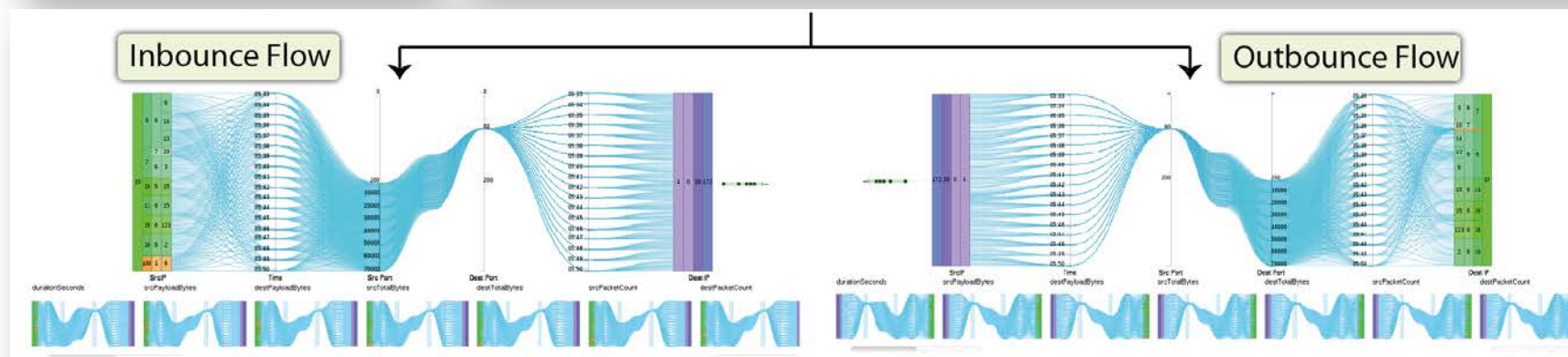
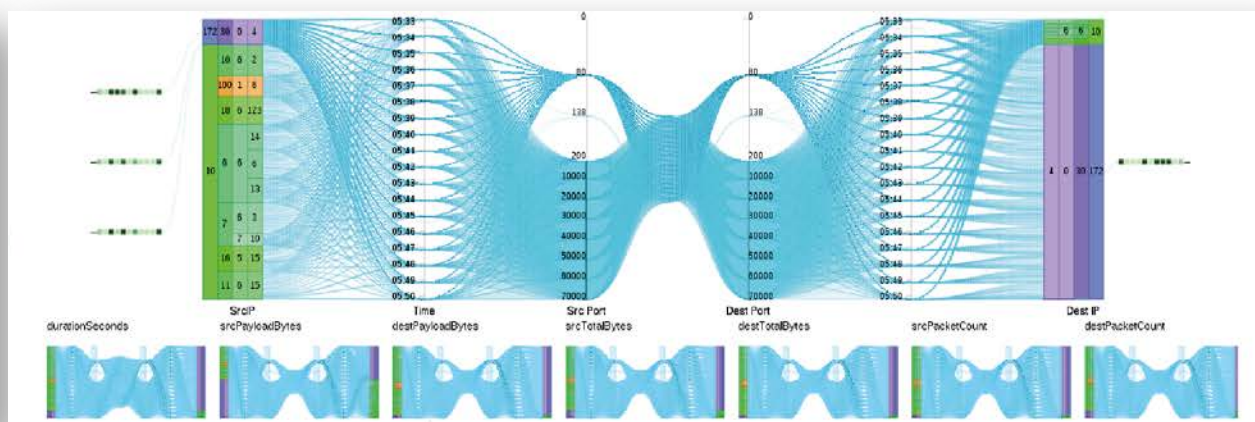
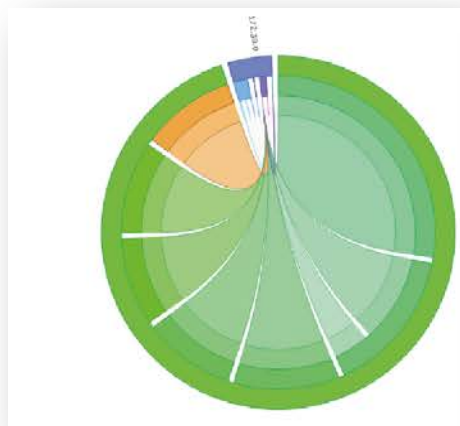
• DoS特征发现 (1)

- 熵视图中，目的IP熵急速下降、源端口熵急速上升
- 大量不同端口连接相同少量端口
- 大量流量爆发



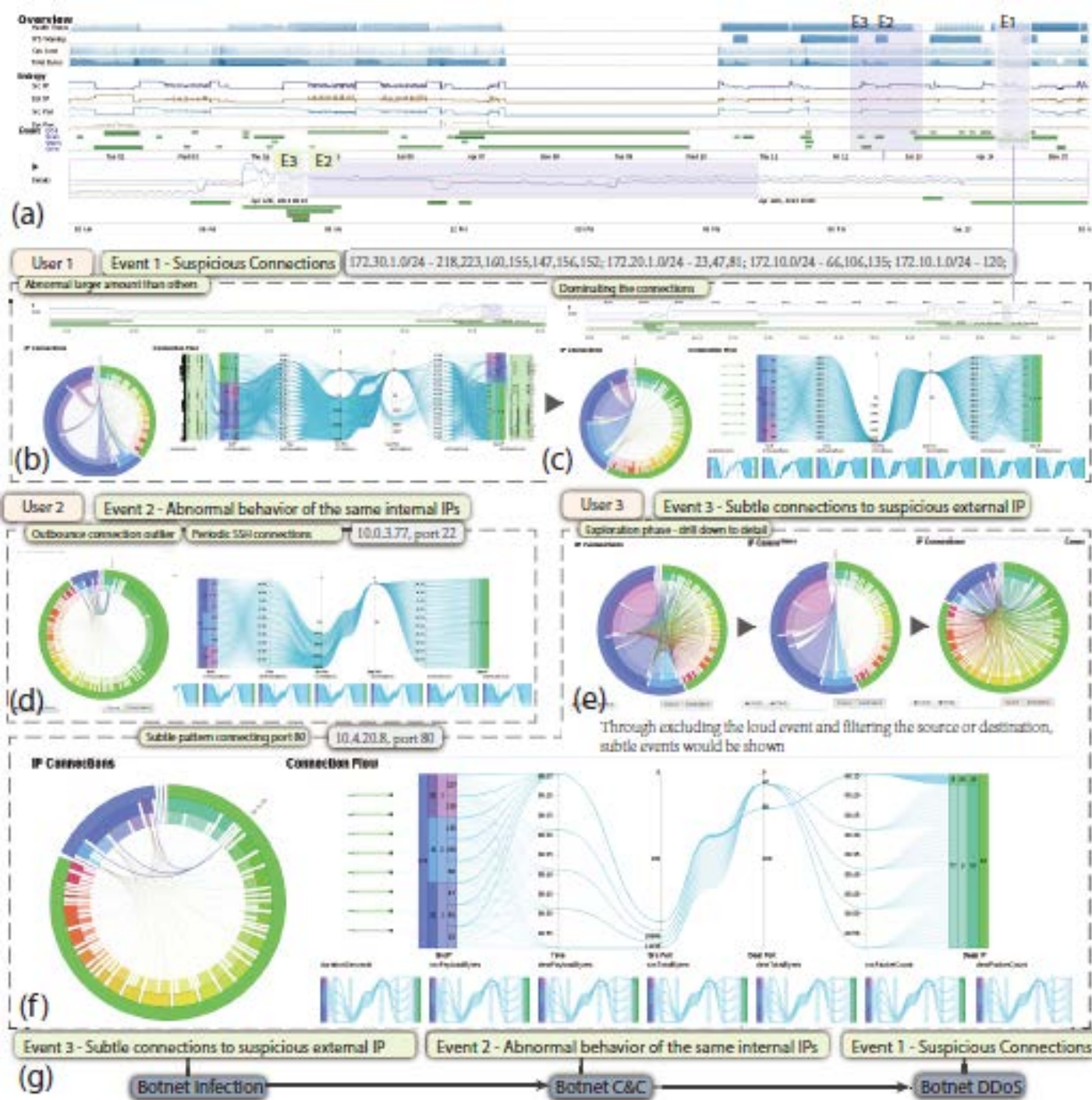
■ DoS特征发现 (2)

- 用户选择感兴趣的时间细节，可以观察不同时间段环状视图中IP连接状况，很明显的攻击前、攻击时与攻击后的连接呈现不同的视觉特征，其中攻击时的IP集中与某几个外网IP，连接至内网服务器，并占有大量网络流量。



• DoS特征发现 (3)

- 大量的高位端口连接流入服务器的80端口
- 通过交互分离出流入、流出的流量，确认为DDoS攻击



多层次可 视分析 --僵尸网络

- (a) 全局时间概览
- (b, c)- E1, 多个内网IP异常大量流量连接外网正常IP (僵尸网络DoS)
- (d)- E2, 在DoS之前往回溯源, 找到这些IP异常周期性SSH至10.0.3.77 (僵尸网络C&C)
- (e, f)-E3, 通过过滤该异常IP的外网连接, 找到僵尸网络的感染源头, 连接异常外网的IP后受木马控制
- (g)- 僵尸网络事件关联分析

VAST CHALLENGE 2014

*VAST 2014
CHALLENGE
The Kronos Incident*

Hyun Li <http://crashlive.com/news/11/contents/121/0/>
Adam Jones <http://crashlive.com/news/11/contents/121/0/>

背景介绍

- 一家Tethys国的跨国公司GAStech，已经在Kronos国发展了20年了。在这20年间，它主要经营天然气的开采工作，产生了可观的利润，并且它也与Kronos政府保持了良好而紧密的关系。但是，它却在环境保护上的作为却遭人诟病。
- 在2014年1月的一天，GAStech的高层举办庆祝典礼来庆祝公司成功的IPO，但在典礼的一半，突然有一些员工消失了！一个叫做Protectors of Kronos的组织被怀疑与这次失踪事件有关，但事情可能并不简单的是我们所看到的那样。
- 作为一名可视分析专家，你受雇与Kronos和Tethys国的法律部门，对整个事件进行评估，并且找出失踪的人在哪里，帮助他们重新回家。时间十分紧迫。

可视分析任务与挑战

总体目标

- 找出事情的真相，员工为何失踪？谁是主谋、动机为何？在合适的时间地点部署警力，救出被困人员
- 整个1月份，各方势力如何周旋，究竟发生了什么？

子目标

- 描述出POK的网络关系图，并且如何随时间变化？
 - 谁是领袖？谁是外延网络的一部分？组织架构如何变化？
 - POK与GAStech有什么潜在的关系？
- 描述出2014年1月20-21日，发生了什么事件（时间地点人物）
- 描述出2014年1月6日-19日，GAStech员工的日常行为，并找出哪些是异常举动？
- 描述出2014年1月23日，发生了什么事件？（根据Streaming数据）

- 1) 新闻数据 – 文本 (845篇 , 时间跨度为20年 , 以及绑架发生前后共3天的密集新闻报道)
- 2) GASTech公司数据 – 文档
 - 人物信息
 - 员工记录表
 - 部分员工简历
 - 组织架构信息
- 3) GASTech员工Email通信数据 (仅标题) - 社会网络数据 (2周 , 1170封)
- 4) GASTech员工车辆GPS轨迹数据 – 时空数据 (685,170条数据 , 33MB)
- 5) GASTech员工刷卡账单、会员卡数据 – 日志数据 (1491条 , 跨度2周)
- 6) 事发后相关的Twitter数据 – 社交媒体数据
- 7) 消防车与警车出警调度数据 – 日志数据
- 8) 背景资料
 - 国家简介、POK简介、地图、Abila城市路网数据

可视分析

挑战

- 多个数据源，不同类型数据
- 时间跨度大（20年），粒度不同（在2014年1月有详细数据）
- 数据中含有不确定性、数据缺失
- 涉及分析种类较多、包括人物之间关系（社交网络）、轨迹刷卡（时空数据）、新闻文本（文本数据）、社交网络（实时流数据）等各类数据分析
- 故事情结扑朔迷离

如何应对

- 设计基本可视化方法 – 看懂数据
- 深入可视分析交互 – 发现内部规律
- 融合不同源数据 – 深入挖掘探索

可视分析

新闻文本数据可视分析

- 对人物关系与事件脉络的探索
- 把握数据时变规律

轨迹、账单数据可视分析

- 时间、空间、人物行为可视化
- 时空筛选与过滤
- 不确定性、数据冲突处理

Twitter、出警记录可视分析

- 时变、话题演变规律
- Streaming数据处理与分发（设计）

多数据融合可视分析（设计）

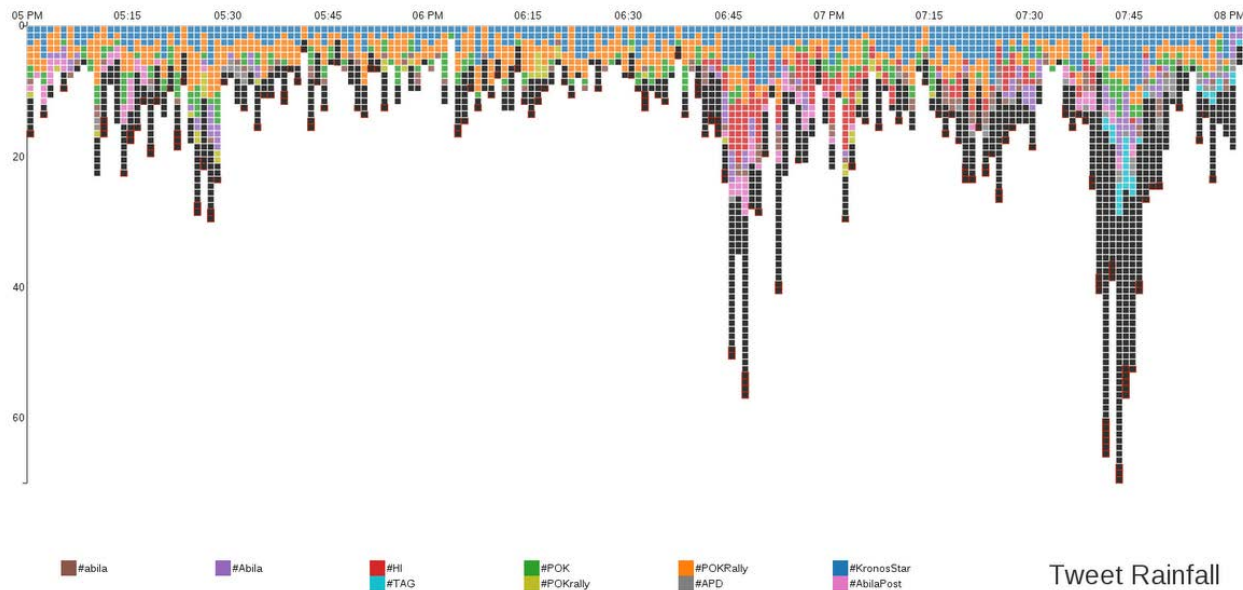
- 以时间为纽带、多尺度分析

Balas	Felix	3	Engineering	Engineer
Barranco	Ingrid	4	Executive	SVP/CFO
Baza	Isak	5	Information Technology	IT Technician
Bergen	Linnea	6	Information Technology	IT Group Manager
Borrasca	Isande	7	Engineering	Drill Technician
Calixto	Nils	8	Information Technology	IT Technician
Calzas	Axel	9	Engineering	Drill Technician
Campo-Corrente	Ada	10	Executive	SVP/CIO
Cazar	Gustav	11	Engineering	Hydraulic Technician
Cocinaro	Hideki	12	Security	Site Control
Ferro	Inga	13	Security	Site Control
Dedos	Lidelse	14	Engineering	Engineering Group Manager
Bodrogi	Loreto	15	Security	Site Control

寻找的样例事件：一名工作人员在非上班时间多次在GAStech出现，并且有时晚归（Jan.7凌晨），并且路上还去了一家化学公司附近的地方逗留了2个小时，之后才回家



Twitter与出警记录流数据分析



Tweet Rainfall

- 话题与时间演变分析
 - X轴是时间
 - Y轴是把每分钟的微博数据进行堆叠排列
 - 将不同的话题抽取，并用颜色来表示

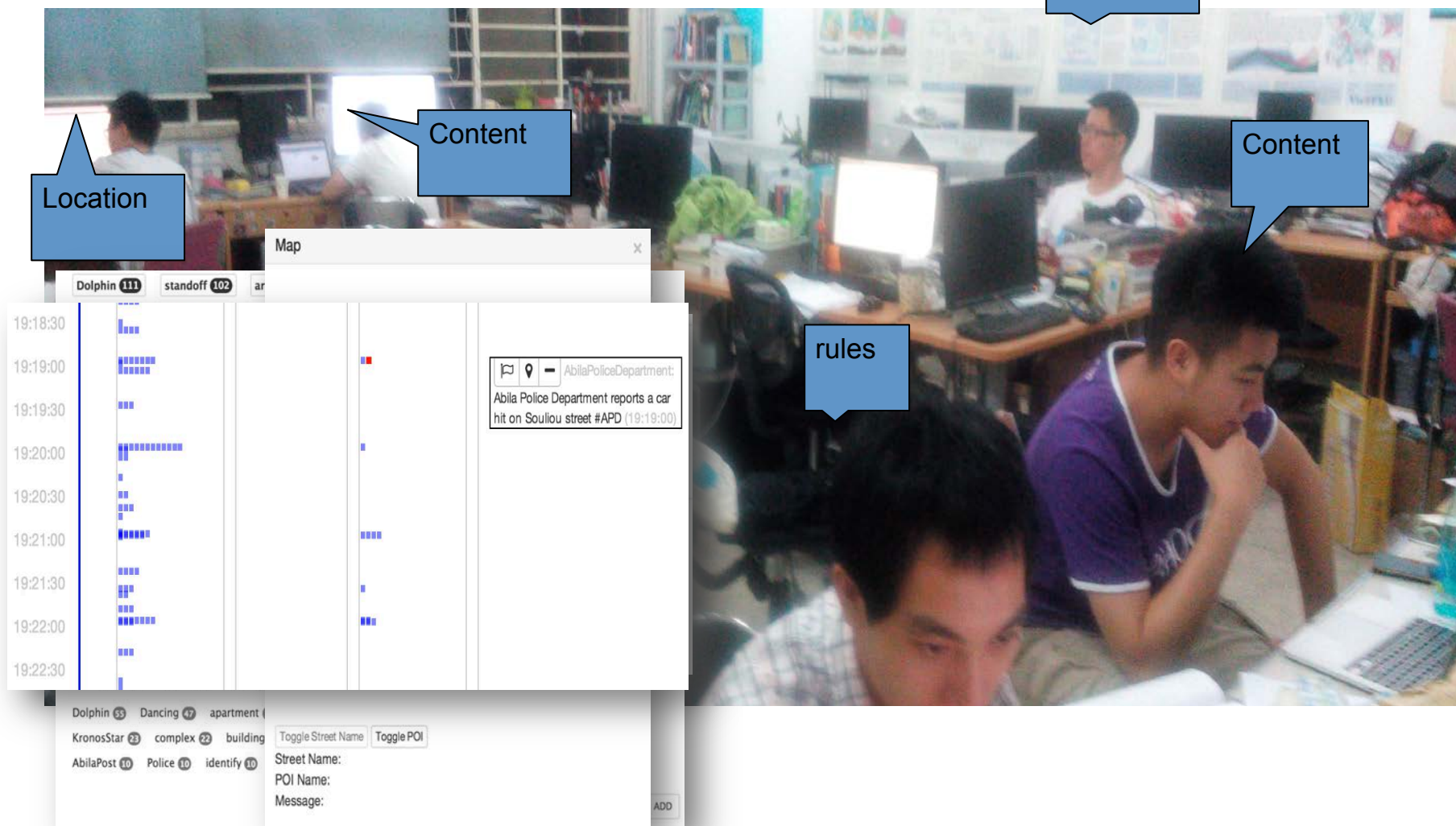
keyword

Location

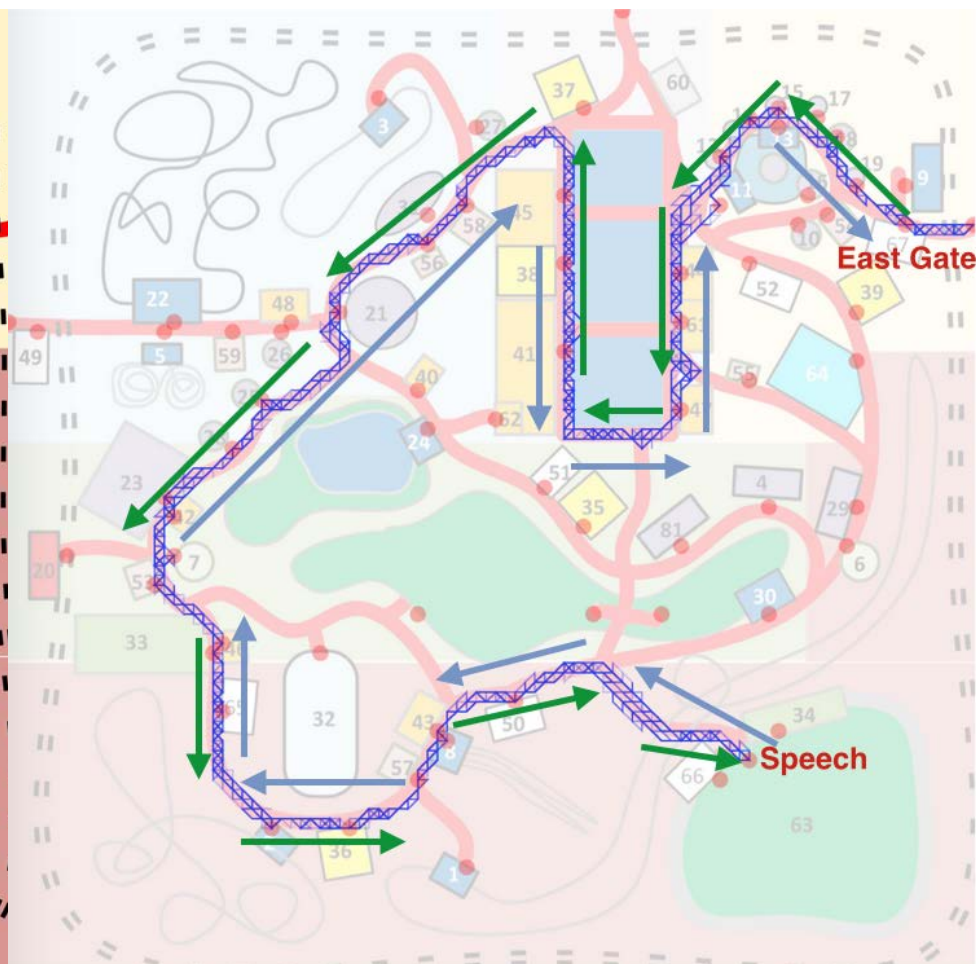
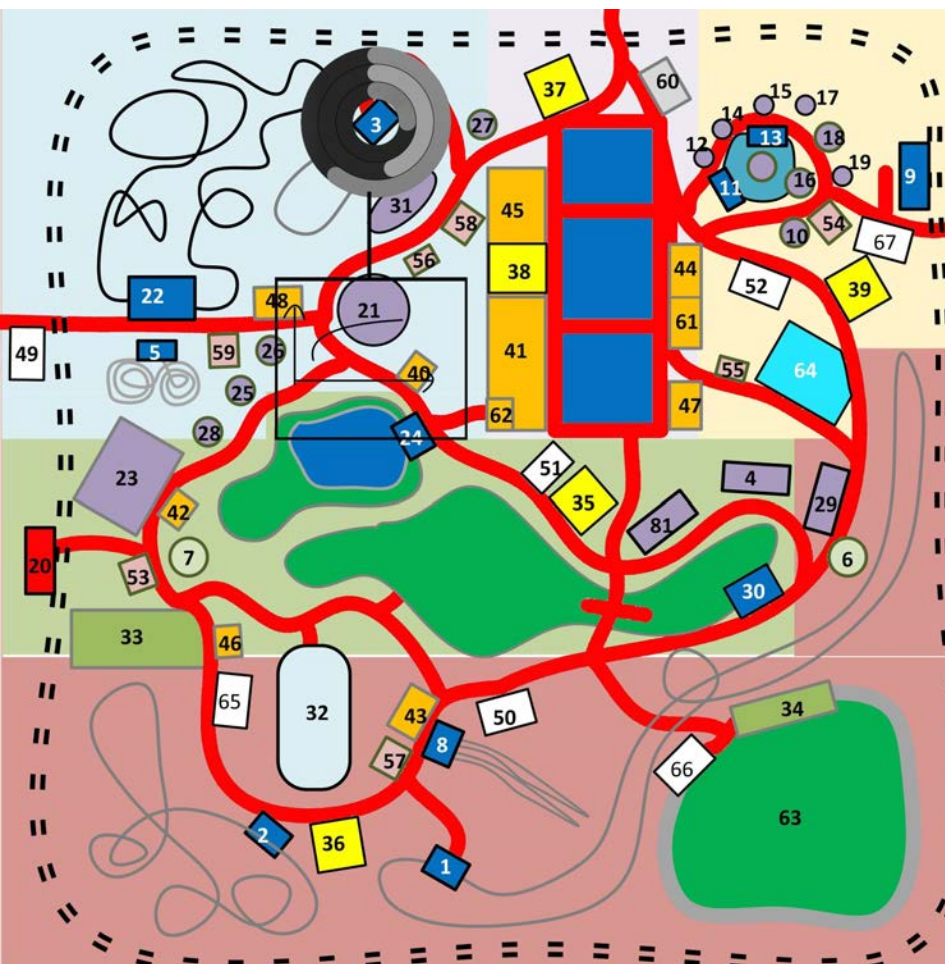
Content

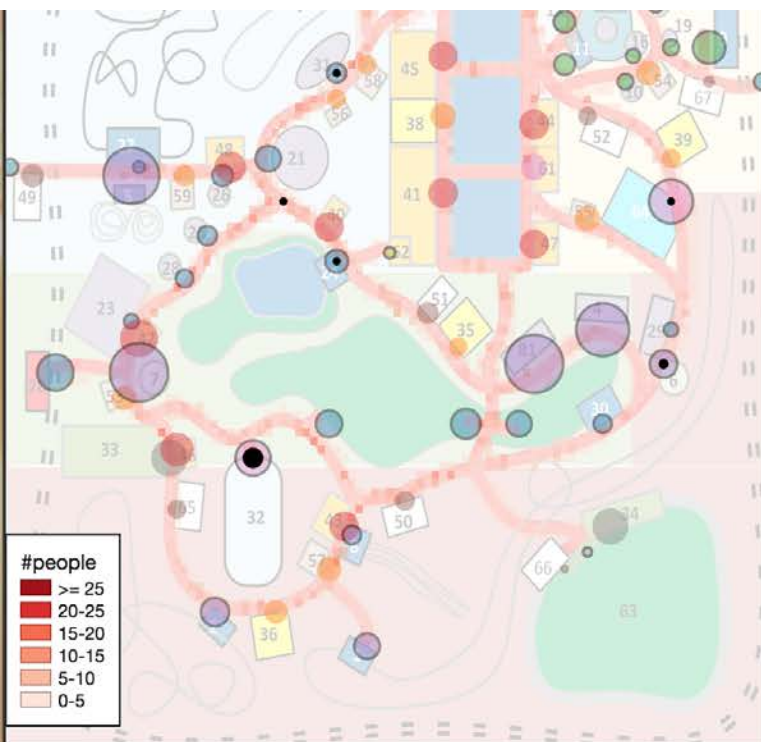
Content

rules

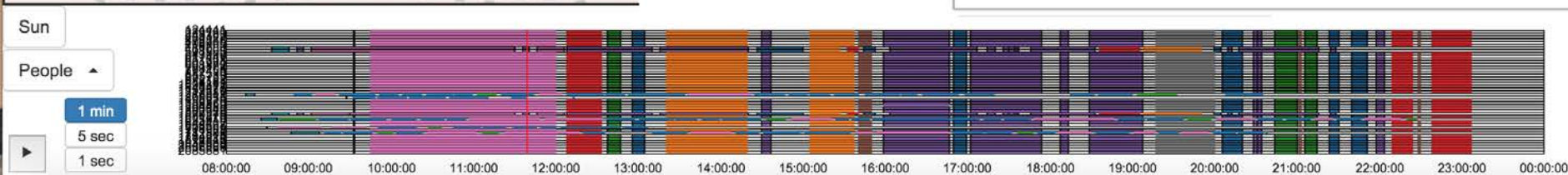
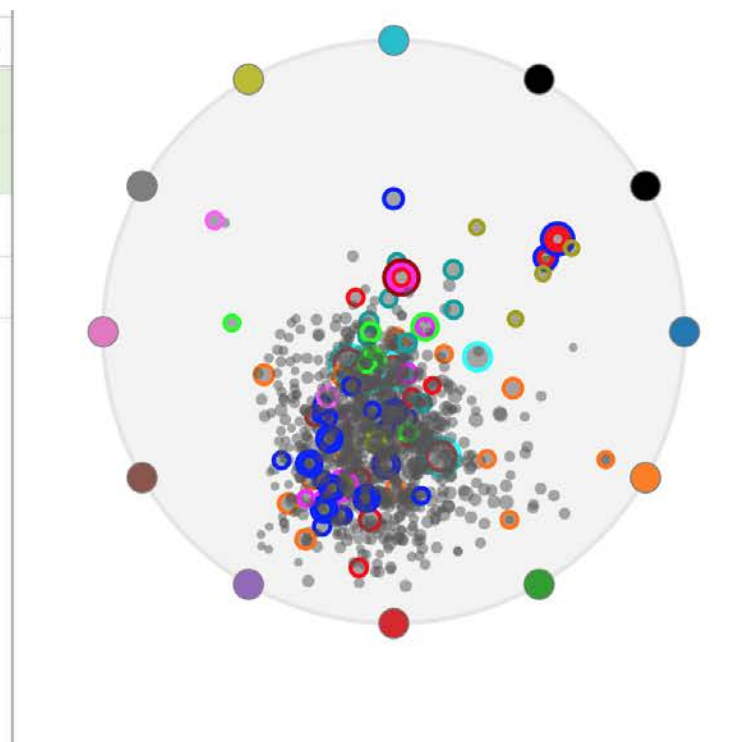


VAST Challenge 2015





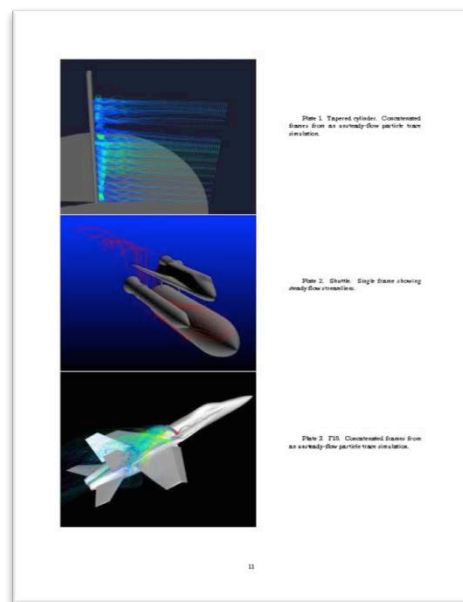
Search for...	Q
2279	large T6 37
3501	T10 unknown 3
3887	suspect unknown 1
3917	suspect unknown 1



第一篇提到“大数据”的论文

First Paper on “Big Data”

- Michael Cox and David Ellsworth, “Application-Controlled Demand Paging for Out-of-Core Visualization.” Proceedings of the 8th IEEE conference on Visualization '97. 1997
- NASA Ames Research Center



第一篇提到“大数据”的论文

First Paper on “Big Data”

1 Introduction

Visualization provides an interesting challenge for computer systems: data sets are generally quite large, taxing the capacities of main memory, local disk, and even remote disk. We call this the problem of big data. When data sets do not fit in main memory (*in core*), or when they do not fit even on local disk, the most common solution is to acquire more resources. This *write-a-check* algorithm has two drawbacks. First, if visualization algorithms and tools are worth developing, then they are worth deploying to more production-oriented scientists and engineers who may have on their

Michael Cox and David Ellsworth, “Application-Controlled Demand Paging for Out-of-Core Visualization.” Proceedings of the 8th IEEE conference on Visualization '97. 1997

极端规模可视分析的十大挑战

Top Ten Challenges of Extreme Scale Visual Analytics

1. In situ Analysis (原位分析)
2. Interaction and User Interface
3. Large Data Visualization
4. Database and Storage
5. Algorithm
6. Data Movement, Data Transport, and Network Infrastructure
7. Uncertainty Quantification (不确定性的定量化)
8. Parallelism
9. Domain and Development Libraries, Frameworks, and Tools
10. Social, Community, and Government Engagements

Pak Chung Wong, Han-Wei Shen, Christopher R. Johnson, Chaomei Chen, and Robert B. Ross, "Top Ten Challenges in Extreme-Scale Visual Analytics," *IEEE Computer Graphics and Applications*, 32(4):63-67, July 2012.

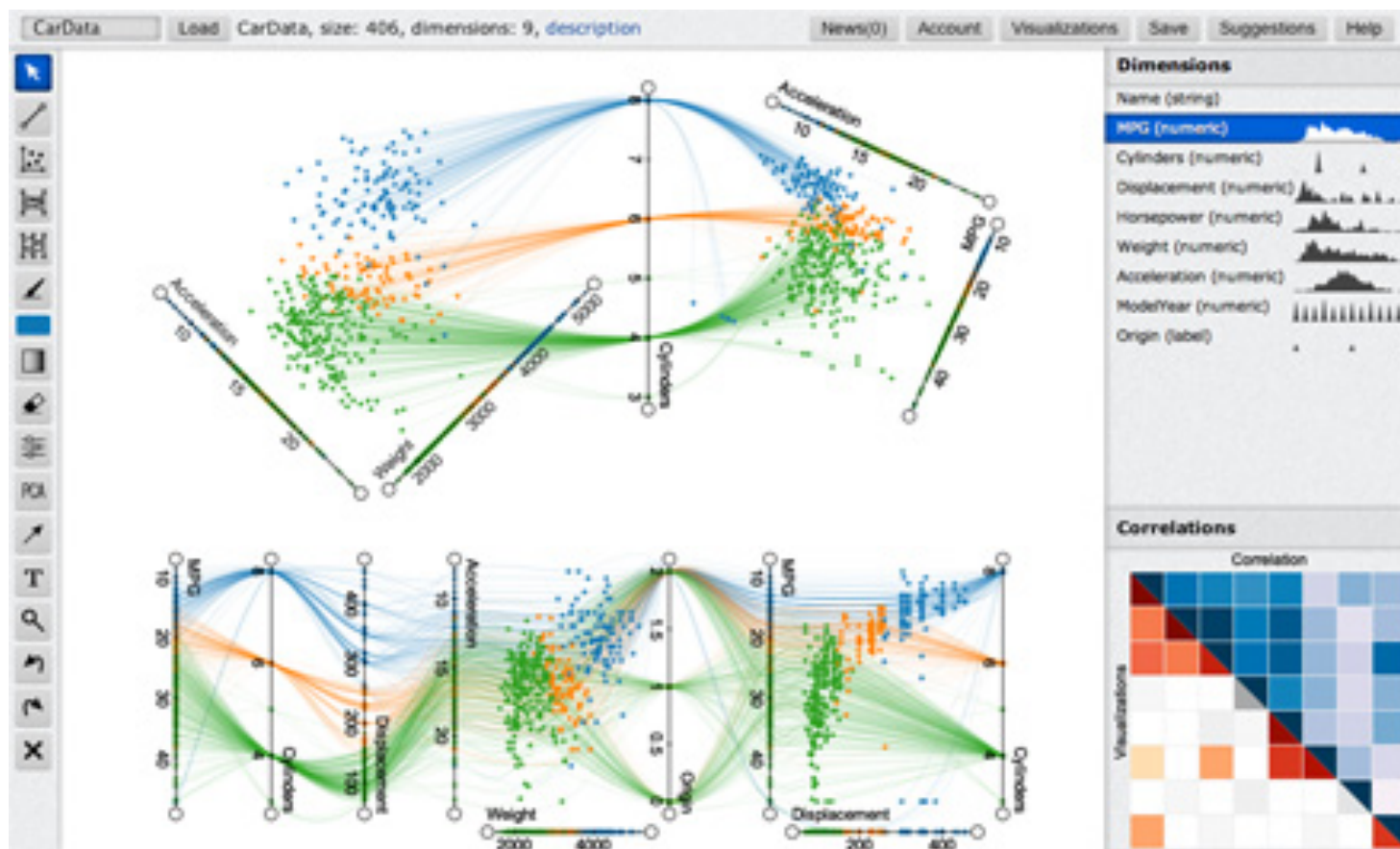
极端规模可视分析的十大交互挑战

Top Ten *Interaction* Challenges of Extreme Scale Visual Analytics

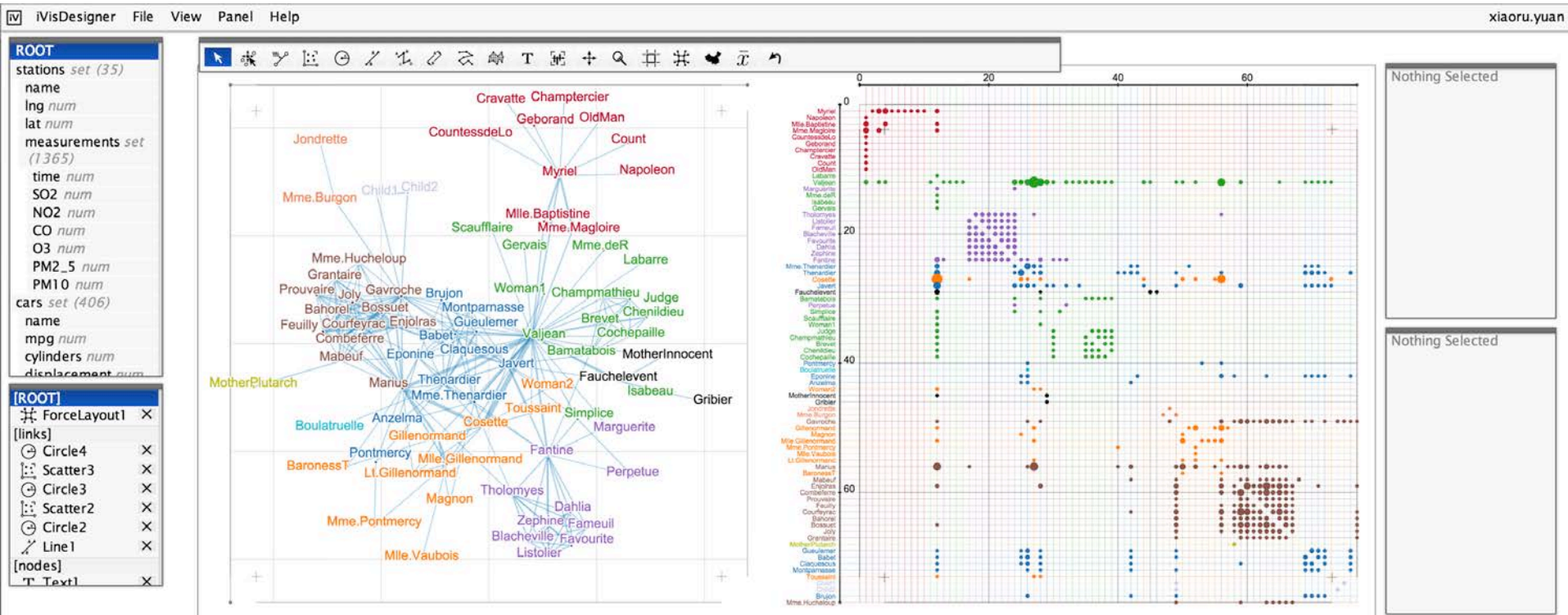
1. In situ interactive analysis (原位交互分析)
2. User-Driven Data Reduction (用户驱动的数据简约)
3. Scalability and Multi-Level Hierarchy (可扩展性与多层次技术)
4. Representation of Evidence and Uncertainty (对证据和不确定性的表示)
5. Heterogeneous Data Fusion (异构数据融合)
6. Data Summarization and Triage for Interactive Query (交互查询的总结与分类)
7. Analytics of Temporally Evolving Features (时变特征分析)
8. The Human Bottleneck (人的瓶颈)
9. Design and Engineering Development (设计与工程研发)
10. The Renaissance of Conventional Wisdom (传统智慧的复兴)

Pak Chung Wong, Han-Wei Shen, and Chaomei Chen, "Top Ten **Interaction** Challenges in Extreme-Scale Visual Analytics," *Expanding the Frontiers of Visual Analytics and Visualization*, pages 197-207, Springer, UK, 2012.

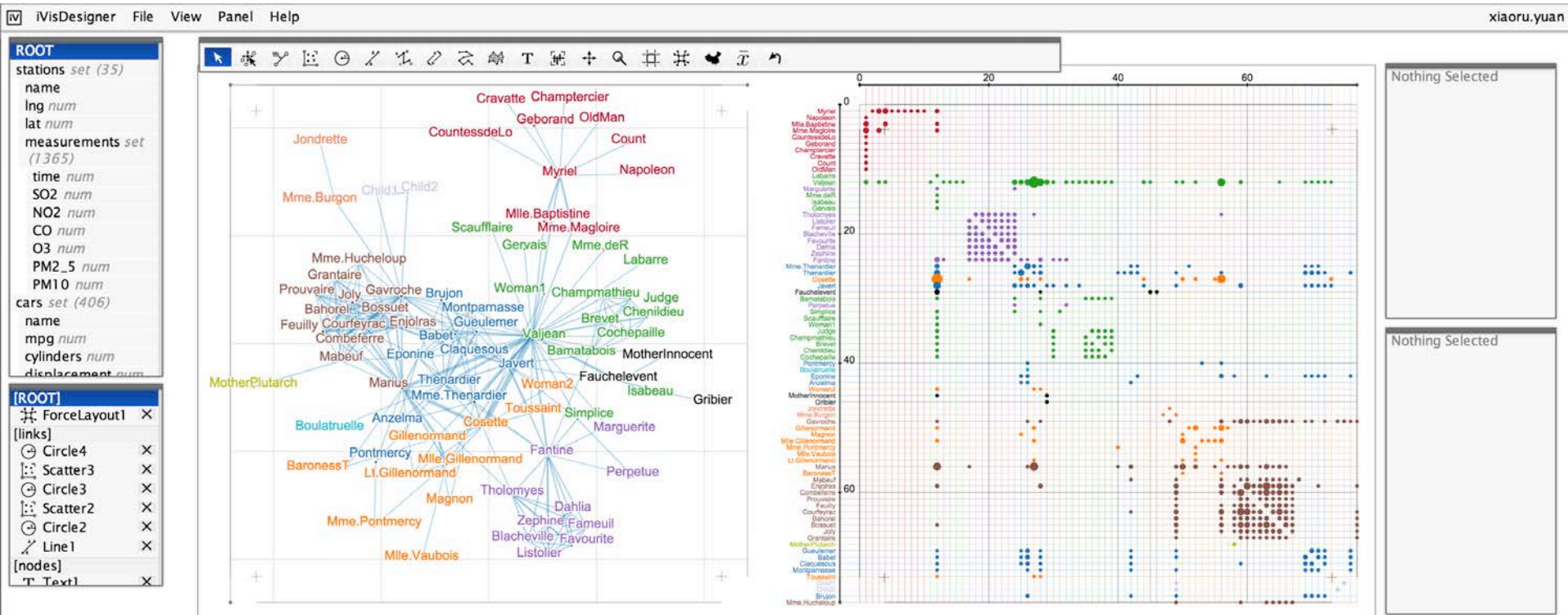
Visualization Assembly Line



iVisDesign



iVisDesign





中国互联网安全大会



360互联网安全中心

谢谢！